

EPICODE — Institute of Technology

WannaCry & DanaBot Analysis

Analisi Statica WannaCry tramite Tria.ge · Analisi Dinamica DanaBot con Procmon e Wireshark

Sandbox cloud Tria.ge per WannaCrypt0r.exe (score 10/10) e analisi comportamentale di DanaBot.exe con monitoraggio Procmon e traffico di rete Wireshark in ambiente isolato FlareVM

Studente	Mauro Picca
Data	3 Giugno 2026
Corso	EPICODE — Cybersecurity & Ethical Hacking
Modulo	S9 L3 — Malware Analysis: WannaCry & DanaBot
Ambiente	FlareVM + Kali Linux (VirtualBox) — Rete isolata 192.168.50.0/24

Attività svolta esclusivamente a fini didattici in ambiente di laboratorio controllato

Cybersecurity & Ethical Hacking | EPICODE

Indice

1. Introduzione	3
Parte 1 — Analisi Statica WannaCry (Tria.ge)	3
2. Identificazione del Campione	3
3. Analisi Tria.ge — Score e Classificazione	4
4. Comportamenti Rilevati	6
5. Traffico di Rete	7
6. Processi Generati e File Rilasciati	8
Parte 2 — Analisi Dinamica DanaBot	9
7. Ambiente e Preparazione	9
8. Esecuzione e Comportamenti Osservati	11
9. IOC Raccolti	14
10. Conclusioni	14

1. Introduzione

L'attività aveva l'obiettivo di analizzare due differenti famiglie di malware utilizzando metodologie di analisi statica e dinamica all'interno di un ambiente controllato.

La prima parte ha riguardato l'analisi del ransomware WannaCrypt0r.exe mediante la piattaforma cloud Tria.ge, senza eseguire direttamente il campione sulla FlareVM — una scelta metodologica che permette di ottenere informazioni comportamentali complete senza rischi per il sistema di analisi.

La seconda parte, opzionale, ha riguardato l'analisi dinamica di DanaBot.exe, un malware bancario, monitorandone il comportamento in tempo reale tramite Procmon e Wireshark all'interno del laboratorio isolato FlareVM + Kali Linux.

⚠ Nota: Tutte le attività sono state svolte in ambienti isolati e controllati a fini esclusivamente didattici. Nessun malware è stato eseguito su sistemi reali o connessi a Internet.

Parte 1 — Analisi Statica WannaCry tramite Tria.ge

2. Identificazione del Campione

Prima di procedere con l'analisi è stato calcolato l'hash SHA256 del campione tramite HashMyFiles, strumento incluso in FlareVM. L'hash è il modo più affidabile per identificare univocamente un campione malware e per cercarlo nelle piattaforme di threat intelligence.

Attributo	Valore
Nome file	WannaCrypt0r.exe
Categoria	Ransomware
Metodo analisi	Sandbox cloud Tria.ge (analisi remota — senza esecuzione locale)
Hash SHA256	Da inserire dopo calcolo con HashMyFiles

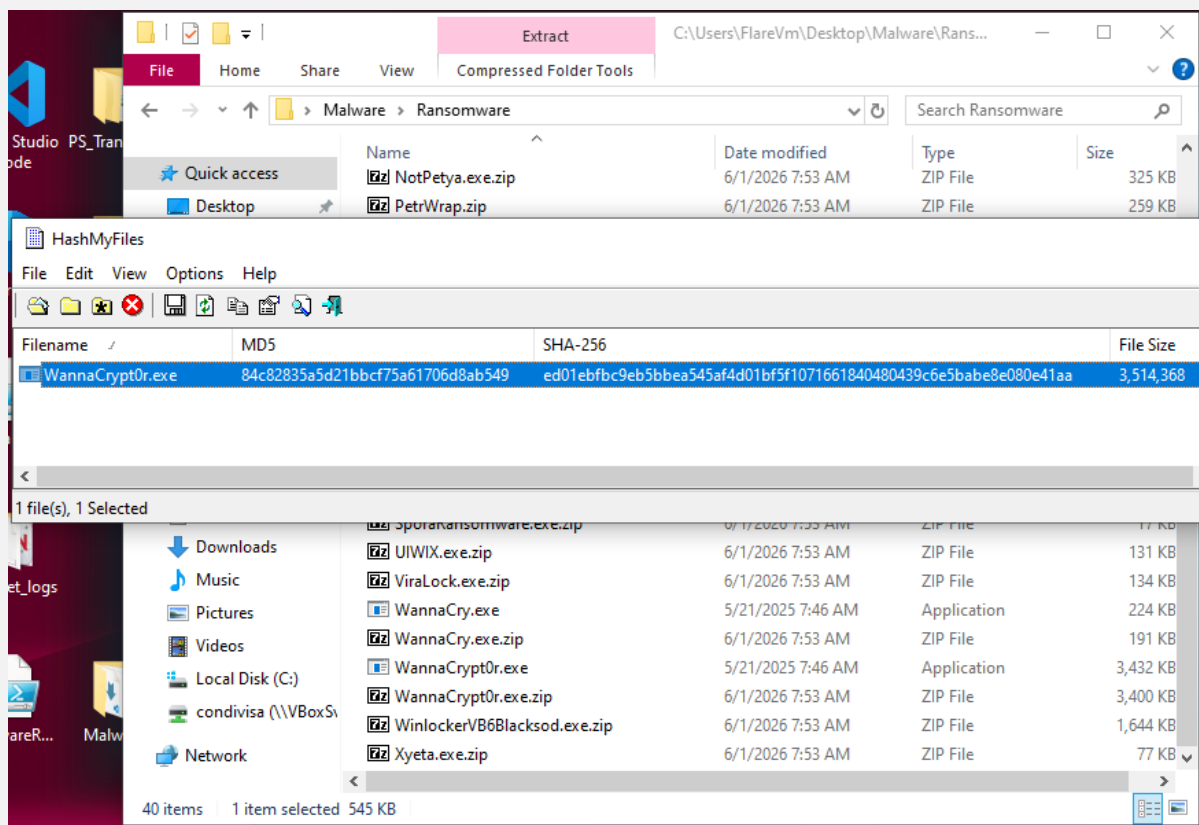


Figura 1 – Calcolo dell'hash SHA256 di WannaCrypt0r.exe tramite HashMyFiles su FlareVM.

💡 Tria.ge è una piattaforma di sandbox cloud che permette di analizzare malware in modo sicuro senza eseguirlo localmente. Il campione viene eseguito in ambienti Windows virtualizzati e isolati, restituendo un report dettagliato su comportamenti, traffico di rete, processi e file rilasciati.

3. Analisi Tria.ge — Score e Classificazione

Il campione è stato caricato su Tria.ge per l'analisi automatizzata. Il sistema ha attribuito al malware un punteggio massimo di pericolosità:

Score Tria.ge: 10 / 10 — Massima pericolosità

Le classificazioni attribuite automaticamente dalla sandbox:

Classificazione	Significato
WannaCry	Appartenenza alla famiglia ransomware WannaCry / WannaCryptor
Ransomware	Cifratura dei file della vittima e richiesta di riscatto
Worm	Capacità di propagazione automatica in rete senza interazione utente
Defense Evasion	Tecniche per sfuggire al rilevamento (MITRE ATT&CK T1497, T1027)
Persistence	Meccanismi per sopravvivere al riavvio del sistema (T1547)
Discovery	Raccolta di informazioni sul sistema e sulla rete (T1082, T1016)
Impact	Cifratura e distruzione dei dati — effetto sull'operatività (T1486, T1490)

The screenshot displays the Recorded Future Triage web interface. The browser address bar shows the URL: `tria.ge/260603-qr9pgafz8x/behavioral1`. The interface includes a navigation bar with 'Submit', 'Reports', and a search bar. Below the navigation bar, there are tabs for 'Overview' (selected), 'Static', and 'WannaCrypt0r[1].exe windows10-2004-x64'. The main content area is divided into several sections:

- Left Sidebar:** Contains buttons for 'Resubmit', 'Download Sample', 'Feedback', 'Print to PDF', and 'PCAPNG'.
- Analysis Section:** Displays key analysis results:
 - user interaction:** yes
 - max time kernel:** 298s
 - max time network:** 278s
 - platform:** windows10-2004_x64
- General Section:** Shows a large 'Score' of 10/10. Below the score, there are buttons for 'MD5', 'SHA1', 'SHA512', 'SSDEEP', and 'TLSH'. To the right, a grid of classification buttons is shown, with 'WANNACRY' highlighted in pink. Other classifications include 'DEFENSE_EVASION', 'DISCOVERY', 'EXECUTION', 'IMPACT', 'PERSISTENCE', 'RANSOMWARE', 'SPYWARE', 'STEALER', 'SURICATA', and 'WORM'.

Figura 2 – Panoramica del report Tria.ge: score 10/10 e classificazioni attribuite al campione.

4. Comportamenti Rilevati

L'analisi delle firme comportamentali rilevate da Tria.ge ha evidenziato attività tipiche di un ransomware moderno con capacità worm. I comportamenti osservati sono coerenti con quanto documentato pubblicamente su WannaCry dopo l'attacco globale del maggio 2017.

Comportamento	MITRE ATT&CK	Descrizione
Eliminazione Shadow Copies	T1490	Cancellazione dei punti di ripristino tramite vssadmin/wmic per impedire il recupero dei file cifrati
Modifica permessi sui file	T1222	icaccls.exe usato per modificare gli ACL dei file prima della cifratura
File di avvio automatico	T1547	Creazione di chiavi Run o task pianificati per la persistenza
Caricamento DLL aggiuntive	T1129	Utilizzo di DLL secondarie per estendere le funzionalità del malware
Lettura dati utente	T1005	Enumerazione dei file utente per identificare quelli da cifrare
Esecuzione componenti secondari	T1059	Lancio di script cmd/cscript e processi ausiliari
Propagazione worm	T1210	Sfruttamento di EternalBlue (MS17-010) per diffusione in rete

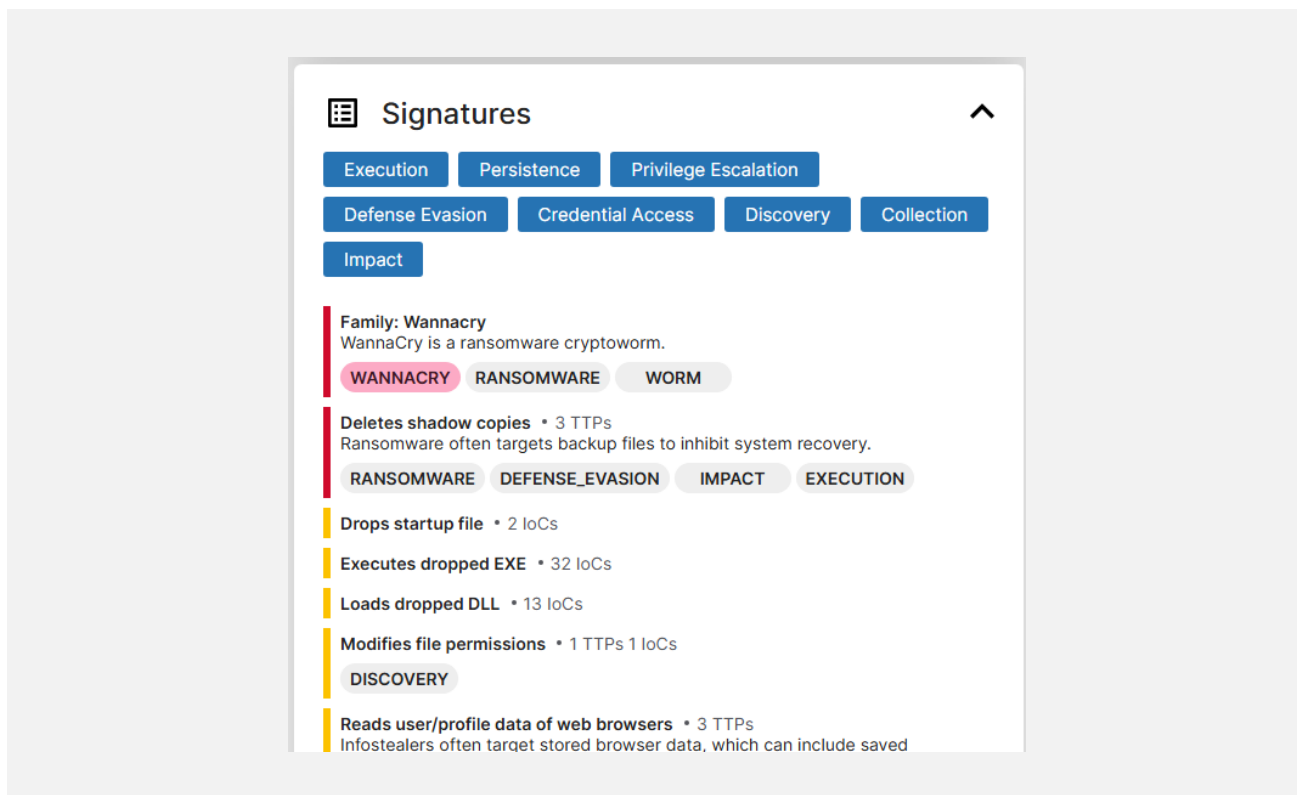


Figura 3 – Signature e tecniche rilevate da Tria.ge con mapping MITRE ATT&CK.

5. Traffico di Rete

Durante l'esecuzione all'interno della sandbox Tria.ge sono state osservate comunicazioni verso domini e servizi esterni. L'analisi del traffico di rete è fondamentale per identificare i server C2 e i canali di comunicazione usati dal malware.

Tra gli elementi identificati nel traffico:

- Richieste DNS — risoluzione di nomi di domini sia malevoli che generici del sistema
- Connessioni HTTP — richieste web verso server remoti
- Accesso a risorse Microsoft CDN — traffico di sistema potenzialmente non malevolo
- Risoluzione di nomi esterni — indicatori del tentativo di raggiungere server C2

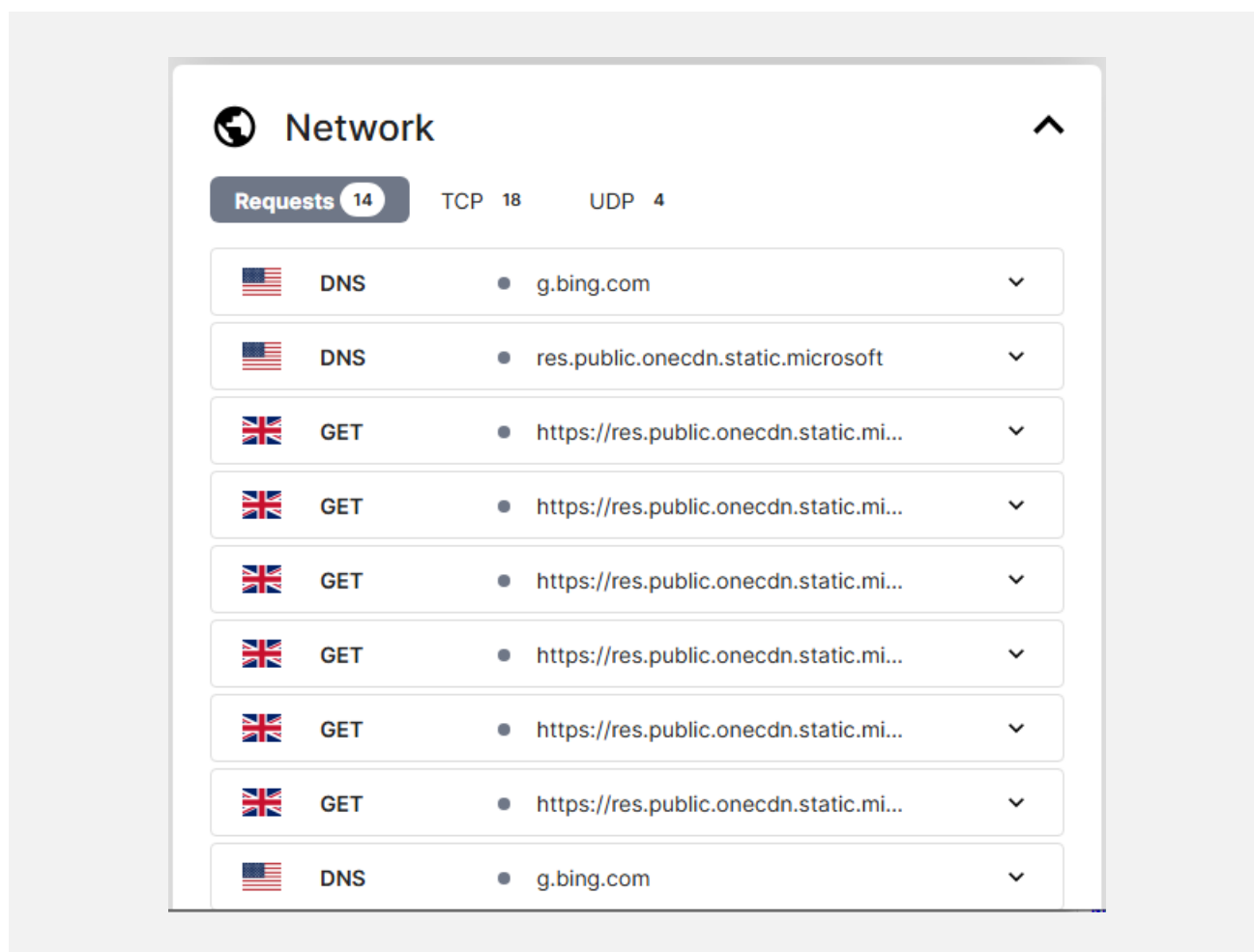


Figura 4 – Traffico di rete osservato nella sandbox Tria.ge durante l'esecuzione di WannaCrypt0r.exe.

🔍 Come appreso nella sessione precedente (S9 L1), è necessario distinguere il traffico realmente malevolo (C2) dal rumore benigno della sandbox (telemetria Microsoft, controllo certificati). I domini CDN Microsoft osservati non sono IOC malevoli.

6. Processi Generati e File Rilasciati

6.1 Processi Generati

L'analisi dell'albero dei processi ha evidenziato la creazione di diversi processi ausiliari, coerenti con le attività tipiche di cifratura, modifica dei permessi e persistenza di WannaCry:

Processo	Scopo
WannaCrypt0r.exe	Processo principale — orchestrazione dell'infezione
attrib.exe	Modifica degli attributi dei file (es. nascondere file)
icacls.exe	Modifica dei permessi ACL sui file prima della cifratura
taskdl.exe	Componente per la cancellazione di file temporanei
cmd.exe	Shell usata per eseguire comandi di sistema
cscript.exe	Esecuzione di script Windows Script Host

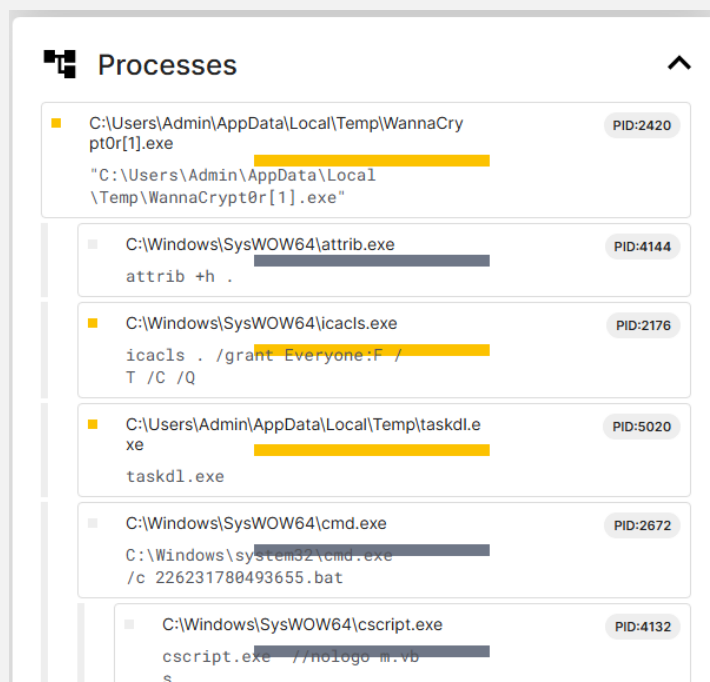


Figura 5 – Albero dei processi generati da WannaCrypt0r.exe nella sandbox Tria.ge.

6.2 File Rilasciati

Durante l'esecuzione il malware ha creato una serie di file temporanei e componenti:

File	Descrizione
00000000.res	File di risorse temporanee usato durante il processo di cifratura
226231780493655.bat	Script batch generato dinamicamente per operazioni di pulizia o persistenza
@Please_Read_Me@.txt	Nota di riscatto — istruzioni per il pagamento in Bitcoin per recuperare i file

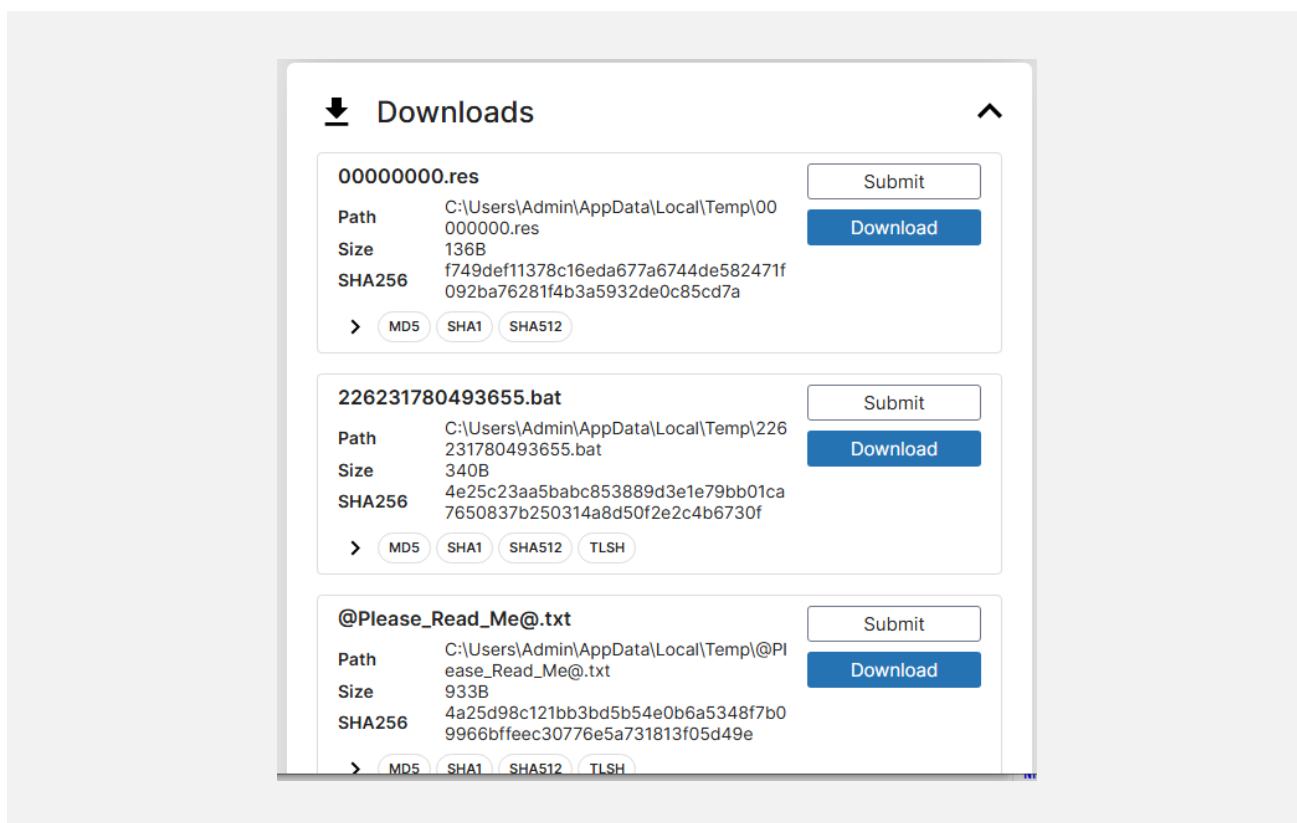


Figura 6 – File rilasciati dal malware: nota di riscatto @Please_Read_Me@.txt e componenti ausiliari.

Parte 2 — Analisi Dinamica DanaBot

7. Ambiente e Preparazione

La seconda parte dell'attività ha previsto l'analisi dinamica di DanaBot.exe in un ambiente isolato. Il campione Emotet originariamente previsto non è risultato eseguibile per l'assenza di Microsoft Word nella FlareVM — l'analisi è stata quindi svolta su DanaBot.exe, un trojan bancario della famiglia DanaBot.

Sistema	Indirizzo IP	Ruolo
FlareVM	192.168.50.150	Macchina vittima — esecuzione del campione DanaBot
Kali Linux	192.168.50.100	Macchina di monitoraggio — osservazione traffico di rete

Prima dell'esecuzione del campione sono stati predisposti i due strumenti di monitoraggio:

Process Monitor (Procmon) — per osservare creazione e modifica di file, accessi al registro e attività dei processi in tempo reale

Wireshark — per catturare e analizzare il traffico di rete generato dal malware

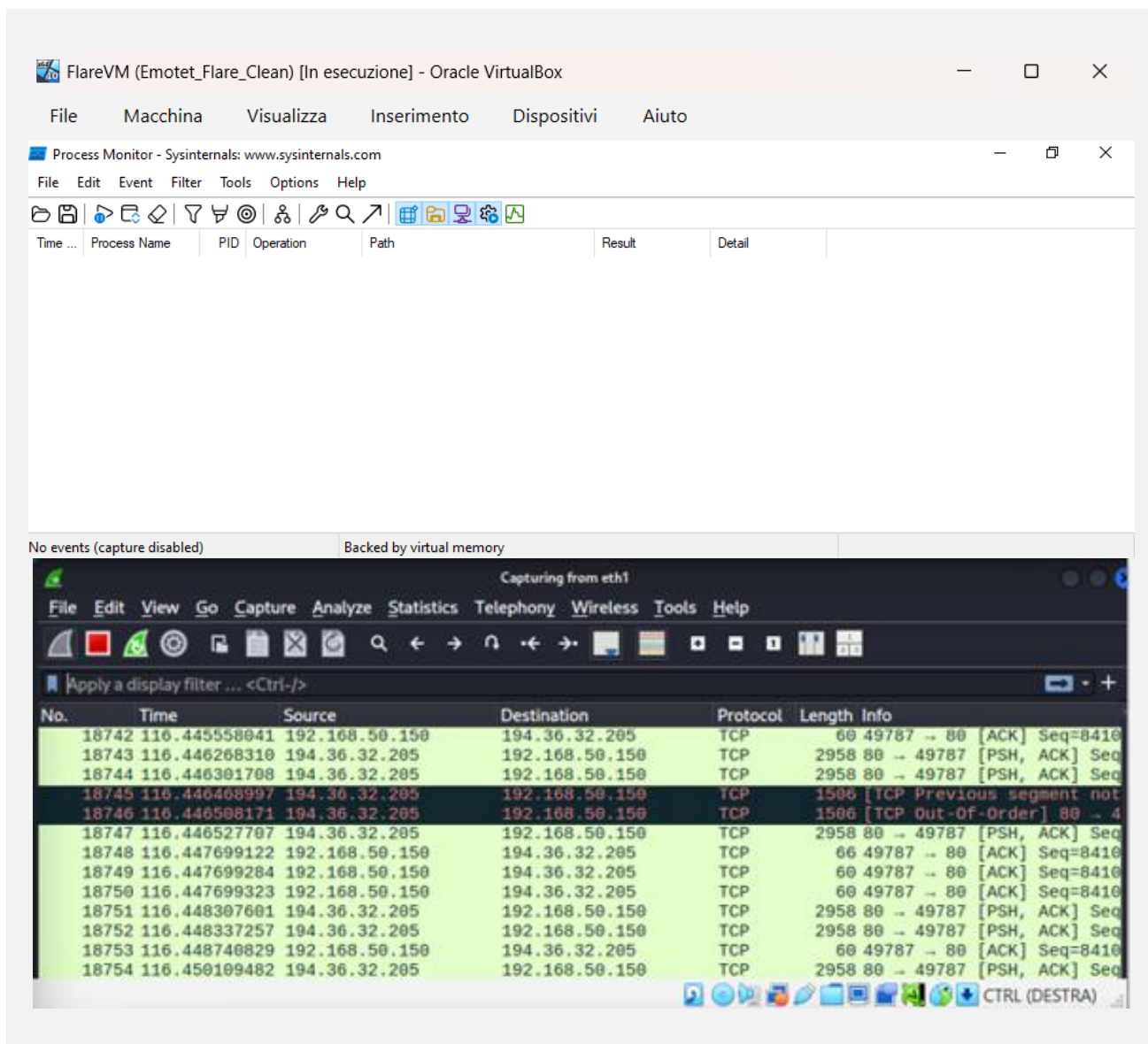


Figura 7 – Procmon e Wireshark predisposti per il monitoraggio prima dell'esecuzione di DanaBot.

💡 DanaBot è un malware-as-a-service (MaaS) bancario scoperto nel 2018. È modulare: il componente principale scarica e installa moduli aggiuntivi per furto di credenziali, form grabbing, accesso remoto e keylogging. Opera principalmente tramite DLL caricate dinamicamente.

8. Esecuzione e Comportamenti Osservati

8.1 Individuazione ed Esecuzione del Campione

Il campione DanaBot.exe è stato individuato nella directory Malware\Banking-Malware della FlareVM e successivamente eseguito con Procmon e Wireshark già attivi per catturare ogni attività fin dal primo istante.

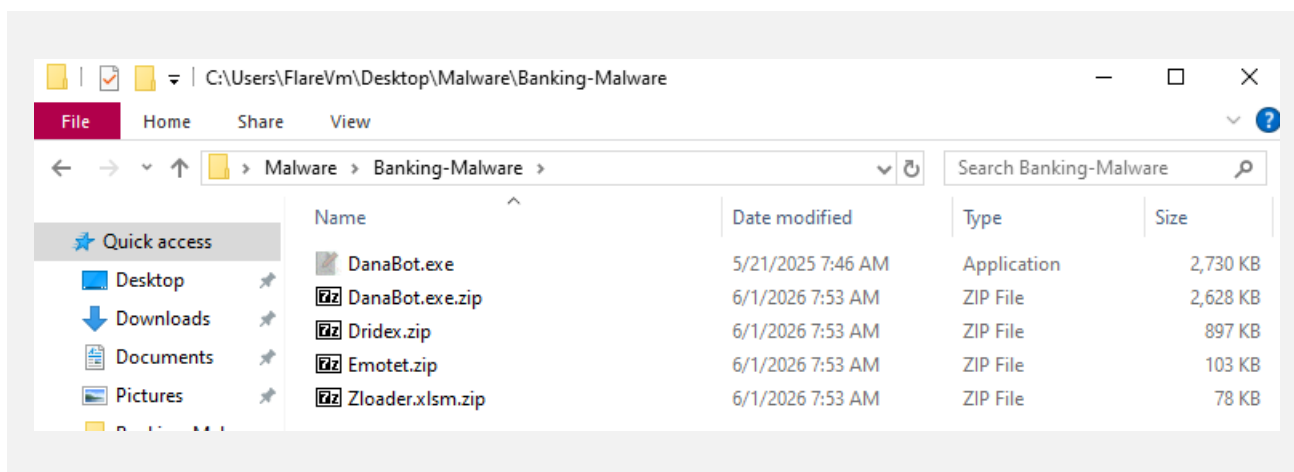


Figura 8 – Individuazione di DanaBot.exe nella cartella Banking-Malware.

8.2 Comportamenti Osservati

Dopo l'esecuzione è stata immediatamente osservata la creazione del file DanaBot.dll nella stessa directory del campione. Questo comportamento — tipico dei malware modulari — indica il rilascio di un componente aggiuntivo che estende le funzionalità del malware durante il processo di infezione.

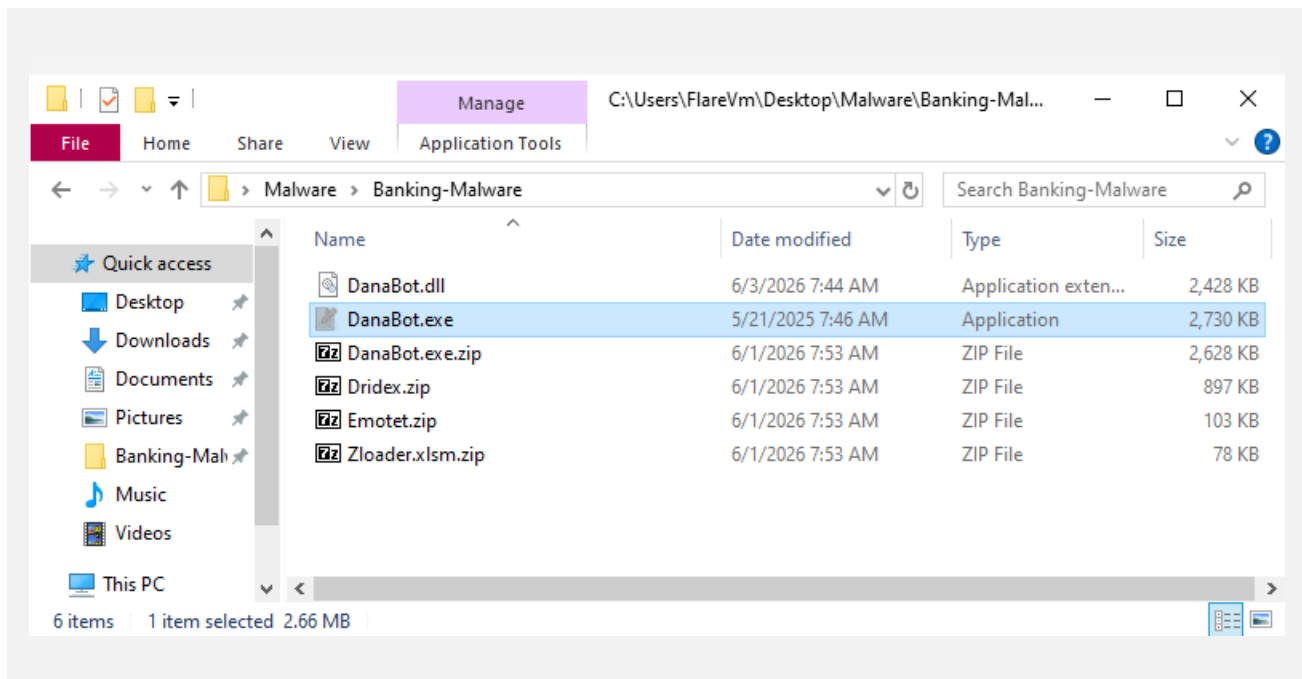


Figura 9 – Esecuzione di DanaBot.exe e comparsa del file DanaBot.dll.

Tramite Procmon sono state rilevate le seguenti attività di sistema:

- interrogazioni del registro di sistema — lettura di chiavi Microsoft Windows per raccogliere informazioni sul sistema
- accessi a chiavi di configurazione Windows — tipico comportamento di ricognizione e persistenza
- attività sul filesystem — creazione di file (DanaBot.dll) e accessi a directory di sistema
- interazioni con la cartella contenente il malware — possibile preparazione per ulteriori componenti

Tramite Wireshark sono state osservate le seguenti attività di rete:

- connessioni TCP verso host remoti — tentativi di raggiungere server C2
- traffico HTTP — possibili richieste di download di moduli aggiuntivi
- richieste DNS — risoluzione di nomi di dominio per individuare i server C2
- comunicazioni verso host remoti — compatibili con il comportamento di un banking trojan che cerca di esfiltrare dati

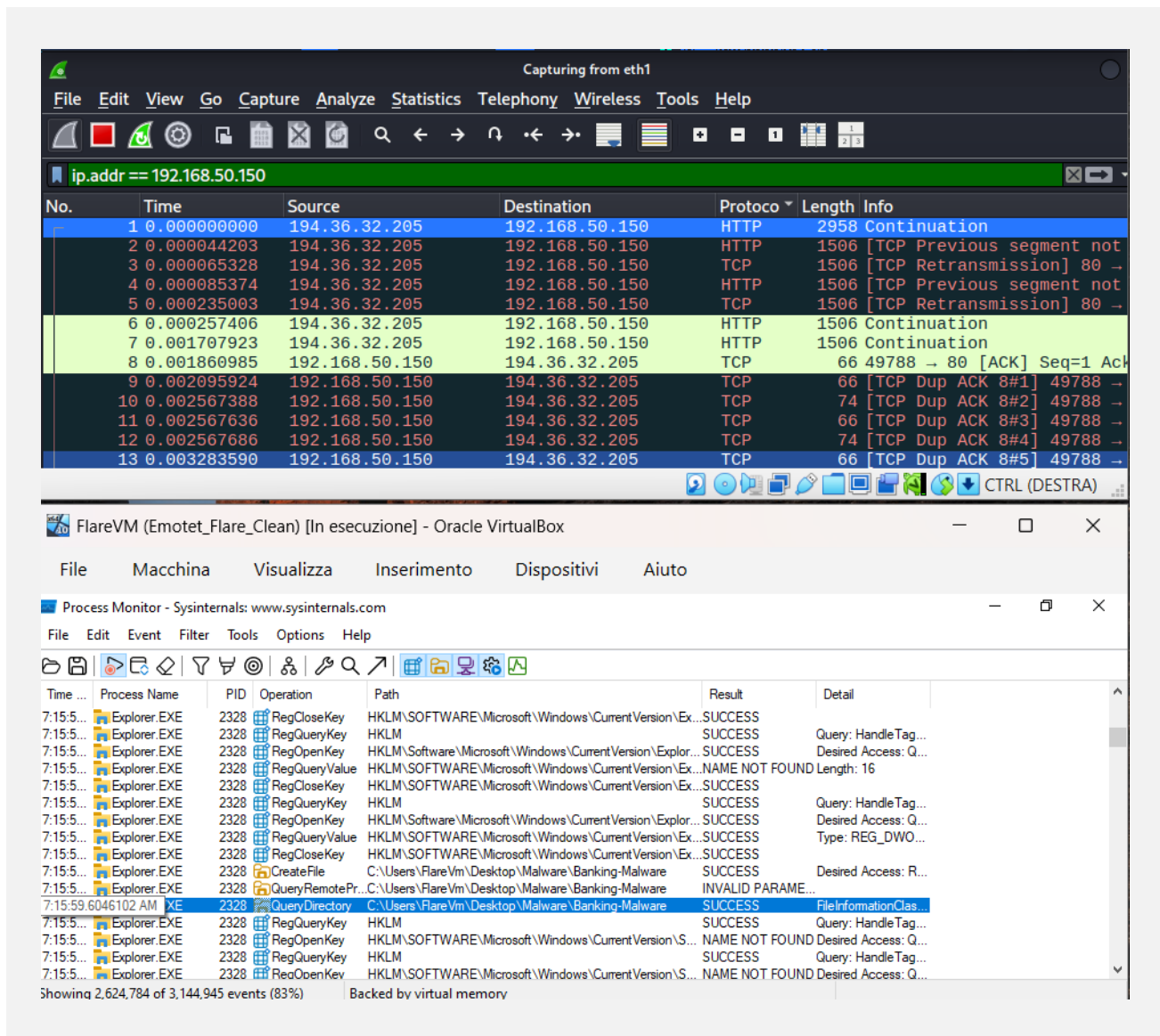


Figura 10 – Attività di rete (Wireshark) e di sistema (Procmon) durante l'esecuzione di DanaBot.

9. IOC Raccolti

L'analisi dinamica ha permesso di raccogliere i seguenti Indicatori di Compromissione (IOC) per il campione DanaBot.exe:

Categoria IOC	Indicatore	Note
File — EXE	DanaBot.exe	Campione principale — banking trojan
File — DLL	DanaBot.dll	Componente modulare rilasciato a runtime
Attività registro	Accessi a chiavi HKLM/HKCU Microsoft Windows	Ricognizione e possibile persistenza
Rete — TCP	Connessioni TCP verso host remoti	Tentativo di comunicazione C2
Rete — HTTP	Traffico HTTP verso server esterni	Possibile download moduli aggiuntivi
Rete — DNS	Richieste DNS verso domini esterni	Risoluzione nomi server C2
Host coinvolto	192.168.50.150 (FlareVM)	Sistema analizzato — macchina vittima

 Gli IOC raccolti in un'analisi dinamica in ambiente isolato sono un punto di partenza: in un contesto reale andrebbero approfonditi con analisi statica approfondita, memory forensics e correlazione con threat intelligence per identificare IP C2, hash dei moduli secondari e YARA rules.

10. Conclusioni

L'attività ha consentito di applicare metodologie di analisi diverse su due famiglie di malware distinte, evidenziando le specificità di ciascun approccio.

Campione	Metodo	Risultati Chiave
WannaCry (WannaCrypt0r.exe)	Analisi statica — Tria.ge	Score 10/10 — Ransomware + Worm + Evasion Shadow copies eliminate, nota riscatto, propagazione EternalBlue 6 processi ausiliari, 3 file rilasciati
DanaBot (DanaBot.exe)	Analisi dinamica — Procmon + Wireshark	Rilascio DanaBot.dll a runtime Accessi registro e filesystem Connessioni TCP/HTTP/DNS verso C2

Il confronto tra i due approcci ha mostrato le rispettive forze: la sandbox cloud Tria.ge fornisce un report completo in pochi minuti senza rischi per il sistema locale, ma dipende dall'esecuzione in un ambiente controllato che il malware potrebbe rilevare. L'analisi dinamica locale con Procmon e Wireshark richiede più preparazione ma permette di osservare comportamenti in tempo reale e di raccogliere IOC specifici.

Lesson Learned

- Le sandbox cloud come Tria.ge sono lo strumento ideale per il triage iniziale: in pochi minuti forniscono score, classificazione, IOC di rete, processi e file rilasciati senza esporre il sistema locale. Sono però soggette a evasione da parte di malware che rilevano l'ambiente virtuale.
- L'analisi dinamica locale con Procmon e Wireshark cattura il comportamento reale in un ambiente che il malware non può distinguere da un sistema reale — è più difficile da evadere. Procmon va avviato prima del malware per non perdere le attività iniziali, che spesso contengono i comportamenti più significativi.
- WannaCry e DanaBot rappresentano due categorie di minaccia distinte: WannaCry causa danno immediato e visibile (cifratura + riscatto), DanaBot opera silenziosamente rubando credenziali finanziarie senza manifestarsi all'utente. La difesa efficace richiede approcci diversi per ciascuna categoria.

- ☒ Tutti gli obiettivi del laboratorio sono stati raggiunti: analisi statica WannaCry tramite Tria.ge e analisi dinamica DanaBot con Procmon e Wireshark completate con successo.

Fine Relazione — WannaCry & DanaBot Analysis | Mauro Picca | S9 L3 | 3 Giugno 2026